



Nombre: Luis Alberto Vargas Gonzalez

Fecha: 05/02/2026

Actividad y unidad: U3 A2: Práctica: Ataque Local Privilege Escalation

Clase: Seguridad de Software.

Maestría en Ciberseguridad.

INTRODUCCIÓN.

En esta práctica de ciberseguridad, similar a las famosas prácticas de CTF (Capture the flag) describiremos el proceso detallado para poder entrar en un sistema en donde para poder realizar acciones contundentes como exfiltración de datos, espionaje permanente, control de usuarios o eliminación de archivos y contenido clasificado tendremos que usar La Táctica 0004 según MITRE ATT&CK la cual es; una escalada de privilegios local, es decir, que no se efectuará por medio de conexiones remotas como ssh, telnet , servidores de control de terminales remotas como TeamViewer, si no que , nosotros ya pudimos conseguir a un usuario que tiene permiso mínimos de acceso dentro del sistema y por medio de un mecanismo de manipulación de cookies en formato web y además basado en deserialización insegura podremos realizar exitosamente la escalada de privilegios.

Cabe destacar que; para la realización exitosa de esta práctica, necesitamos de una herramienta de interceptación de cookies, sesiones y escaneo de componentes web llamada **Burp Suite**, existiendo otras herramientas igualmente efectivas como **Caedo** que realizan las mismas funciones, sin embargo, para apegarnos fielmente a las instrucciones del laboratorio usaremos Burp Suite, siendo además una herramienta que ya he usado previamente en otras plataformas de hacking web.

DESARROLLO.

Antes de pasar a la descripción de la práctica explicaremos de manera concreta los diferentes métodos de acceso que se implementan en sistemas de informática en el mundo real.

El control de acceso es una forma de autorizar/negar acceso a recursos informáticos y corporativos utilizando políticas que verifican que los usuarios que intentan acceder sean efectivamente quien afirman ser y garantiza que se otorguen los permisos y accesos únicamente necesarios a dichos usuarios en esos recursos.

Estos controles de acceso nos permiten combatir con eficacia los distintos tipos de riesgos que conllevan los sistemas informáticos en las organizaciones siendo la **filtración de información, ataques de Buffer Overflow**, y las **suplantaciones de identidad** los más comunes y peligrosos dentro de estos riesgos y ataques en sistemas web civiles y militares incluso.

Existen varios tipos de controles de acceso que las organizaciones pueden implementar para proteger sus datos y usuarios. Estos incluyen:

1. Control de Acceso Basado en programación (PAC)

Usa una matriz de privilegios que se almacena en memoria en una Base de datos y que por medio de código están siendo consultados en tiempo real dichos permisos para otorgar o denegar acceso a los sistemas informáticos.

2. Control de Acceso Discrecional (DAC)

Los modelos DAC permiten al propietario de los datos decidir el control de acceso asignando derechos de acceso a las reglas que los usuarios especifican. Cuando a un usuario se le otorga acceso a un sistema, puede proporcionar acceso a otros usuarios según lo considere conveniente.

3. Control de Acceso Obligatorio (MAC)

MAC establece políticas estrictas sobre los usuarios individuales y los datos, recursos y sistemas a los que desean acceder. Las políticas son gestionadas por el administrador de una organización. Los usuarios no pueden alterar, revocar ni establecer permisos.

4. Control de acceso basado en funciones (RBAC)

RBAC crea permisos basados en grupos de usuarios, roles que los usuarios tienen y acciones que los usuarios realizan. Los usuarios pueden realizar cualquier acción habilitada para su función y no pueden cambiar el nivel de control de acceso que se les asigna.

Identificación de Métodos de Acceso.

En este escenario, la aplicación utiliza un control de acceso basado en RBAC (Role-Based Access Control).

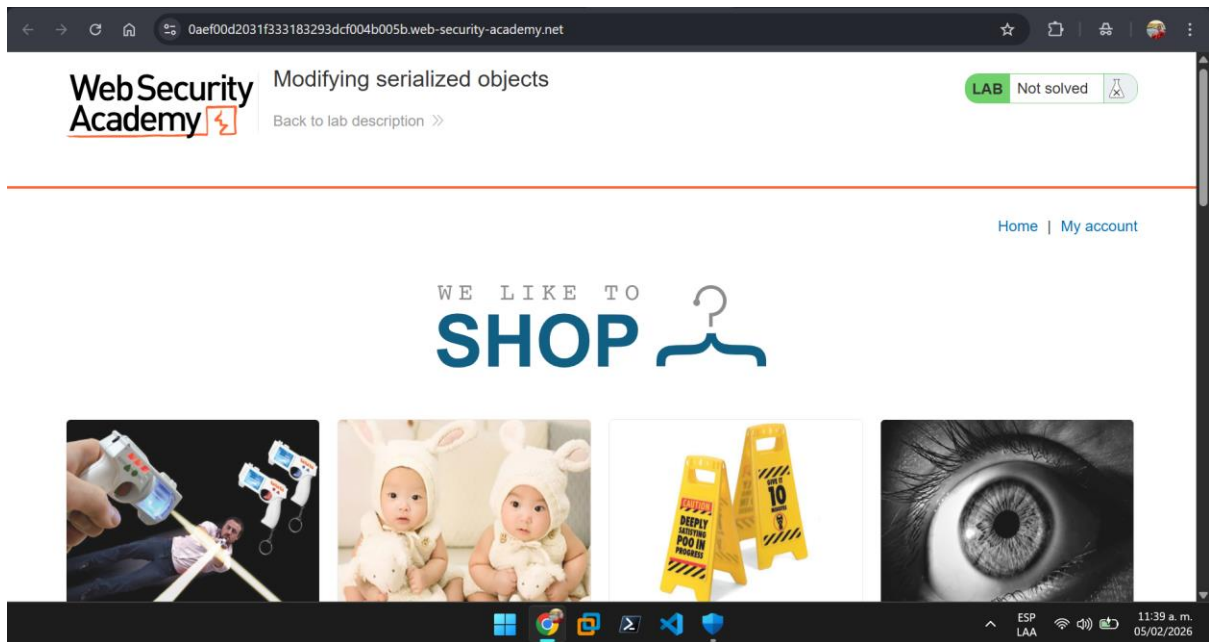
Mecanismo: La identidad y los permisos del usuario no se verifican únicamente en una base de datos del lado del servidor cada vez, sino que se almacenan dentro de un objeto serializado contenido en una cookie de sesión.

El fallo: El sistema confía en que el atributo admin del objeto que envía el usuario es legítimo. Al no haber una firma digital (como un HMAC) que valide la integridad de la cookie, el método de acceso es vulnerable a la manipulación directa.

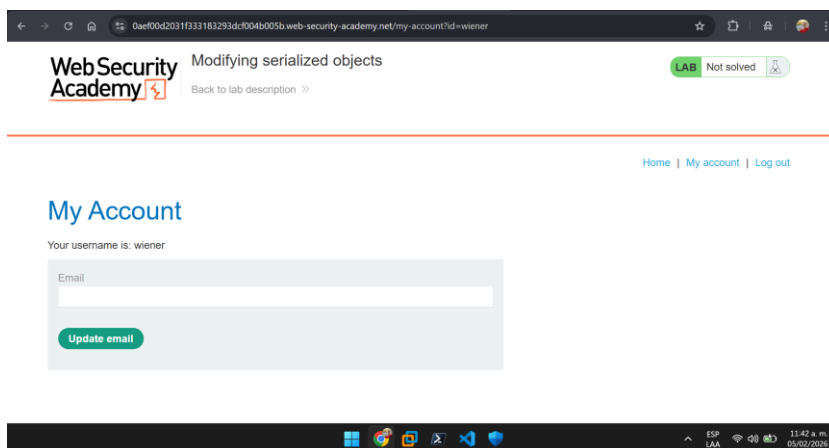
La **deserialización insegura** ocurre cuando una aplicación toma datos estructurados de una fuente no confiable (como una cookie) y los reconvierte en un objeto de programación sin la debida validación.

- **El proceso:** El servidor toma la cadena serializada, reconstruye el objeto en memoria y comienza a usar sus propiedades.
- **Riesgos asociados:**
 - **Escalada de Privilegios:** Modificar atributos como `isAdmin: true`.
 - **Bypass de Autenticación:** Cambiar el username para suplantar a otro usuario.
 - **RCE (Remote Code Execution):** Si se usan "gadget chains", un atacante podría ejecutar comandos en el servidor.

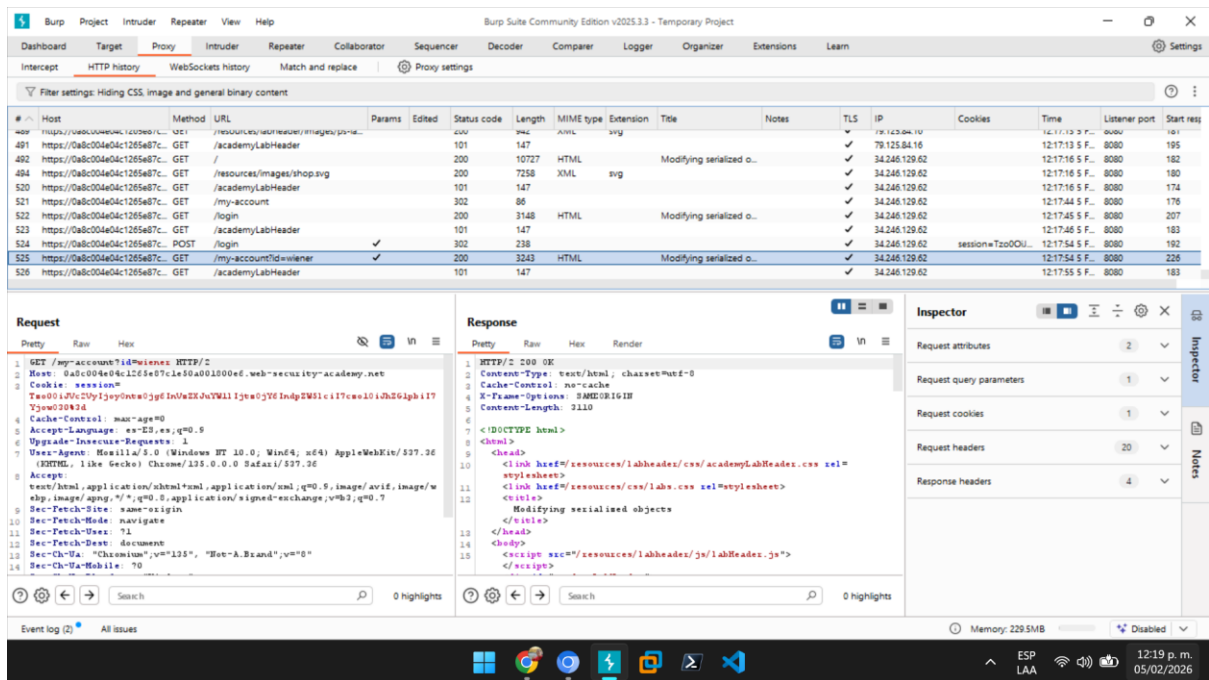
Como primer paso accedemos al sitio web.



Después accederemos con el usuario que previamente nos han compartido con el usuario: Wiener y contraseña: Peter

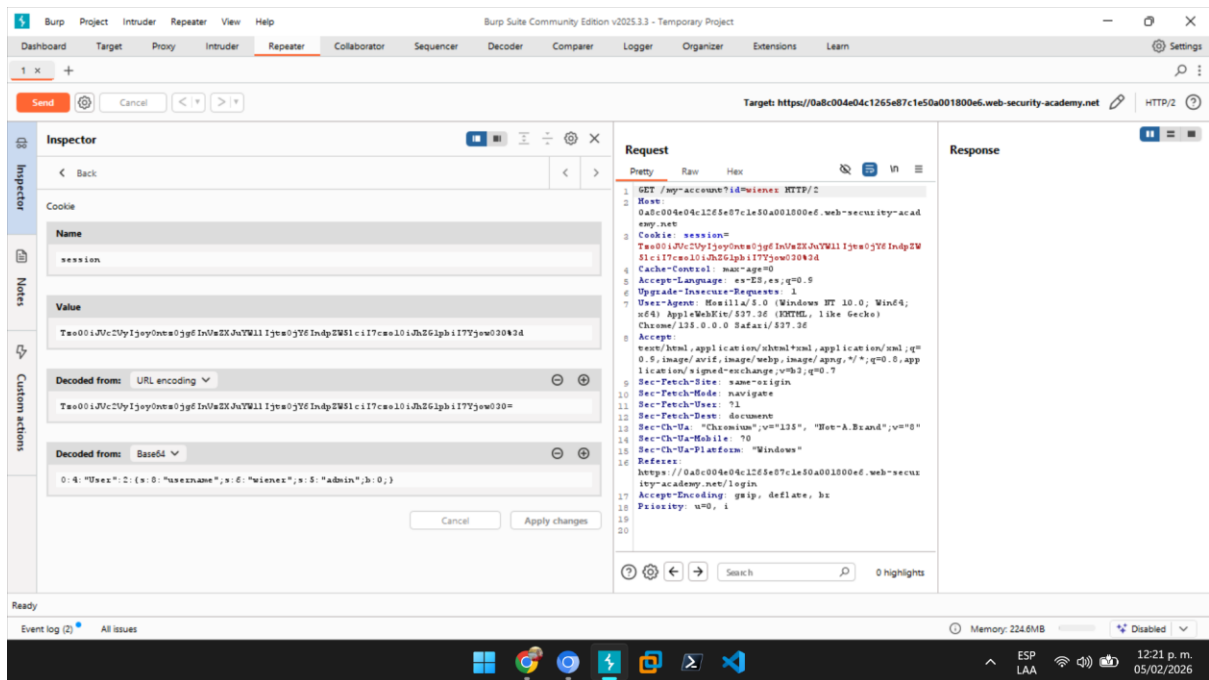


Posteriormente capturaremos con Burp Suite la petición de la cookie para poder proceder con la deserialización.

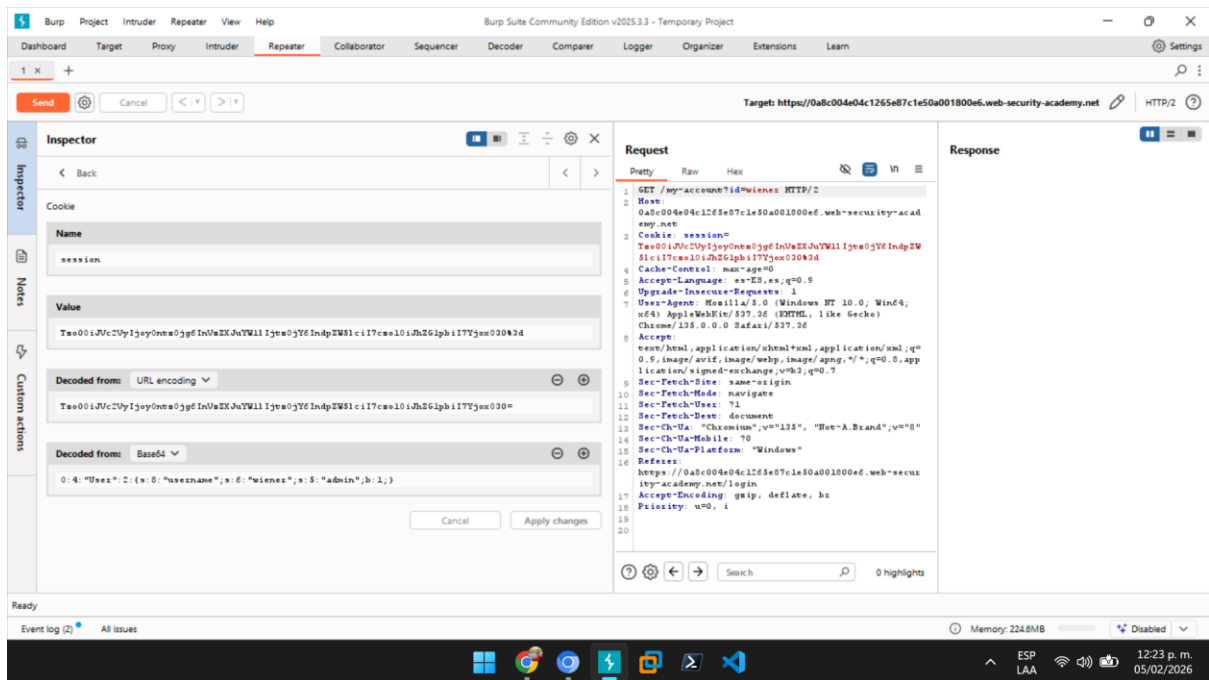


Cabe destacar que para poder capturar la cookie de sesión correctamente necesitamos tener el interceptor desactivado para que podamos navegar fluidamente, acceder al historial de peticiones http y que no existan bloqueos en el sitio web del laboratorio.

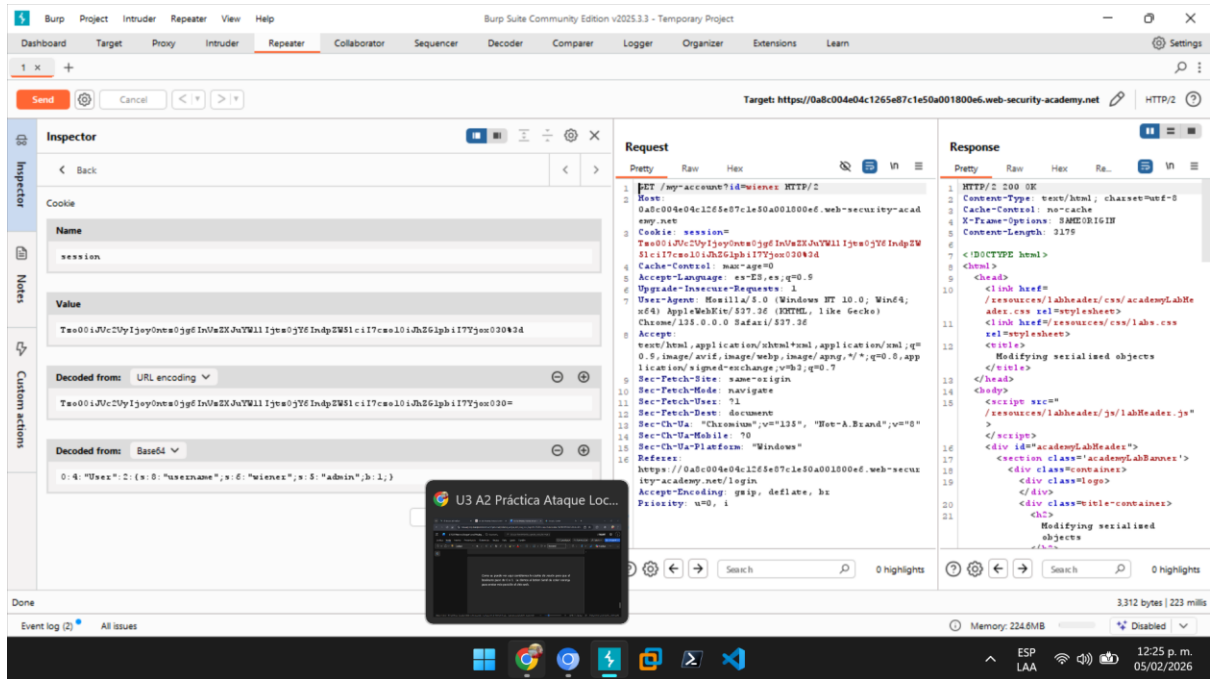
Posteriormente usaremos el Repeater para no tener que estar refrescando el sitio web constantemente y guardar muchas veces la nueva cookie.

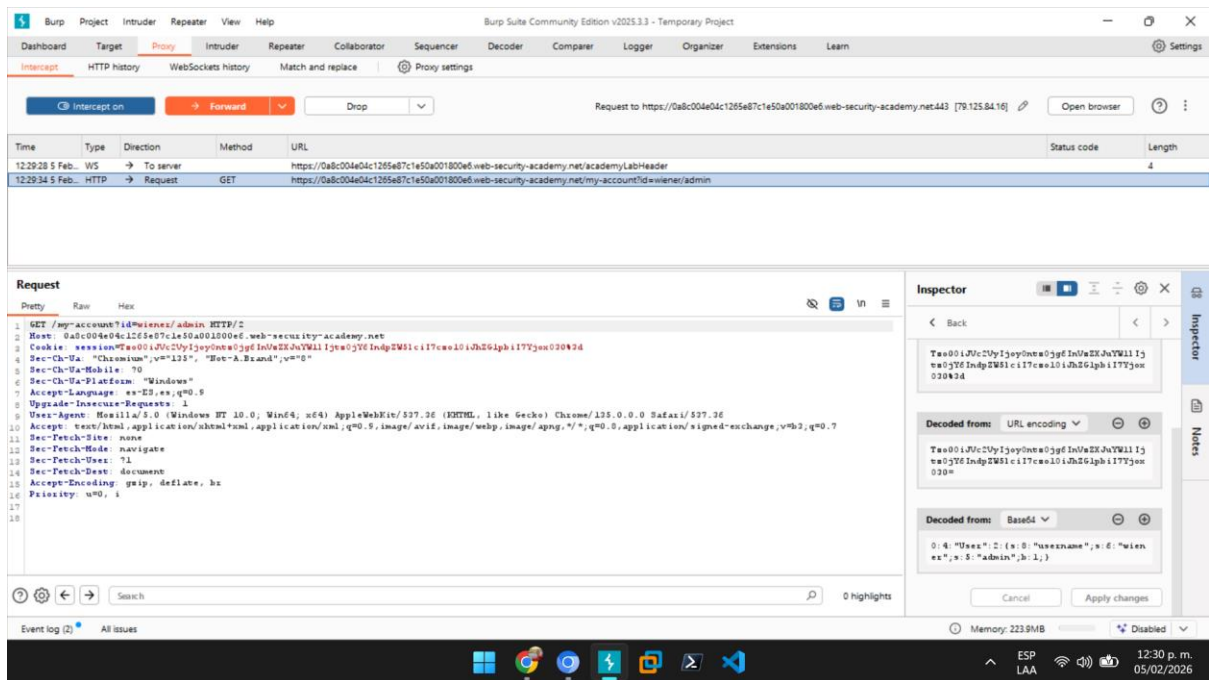


Aquí podemos notar que en la Pestaña del Repeater usando el inspector veremos la cookie de sesión decodificada en Base64 lo cual nos será útil para poder modificar dicha cookie.

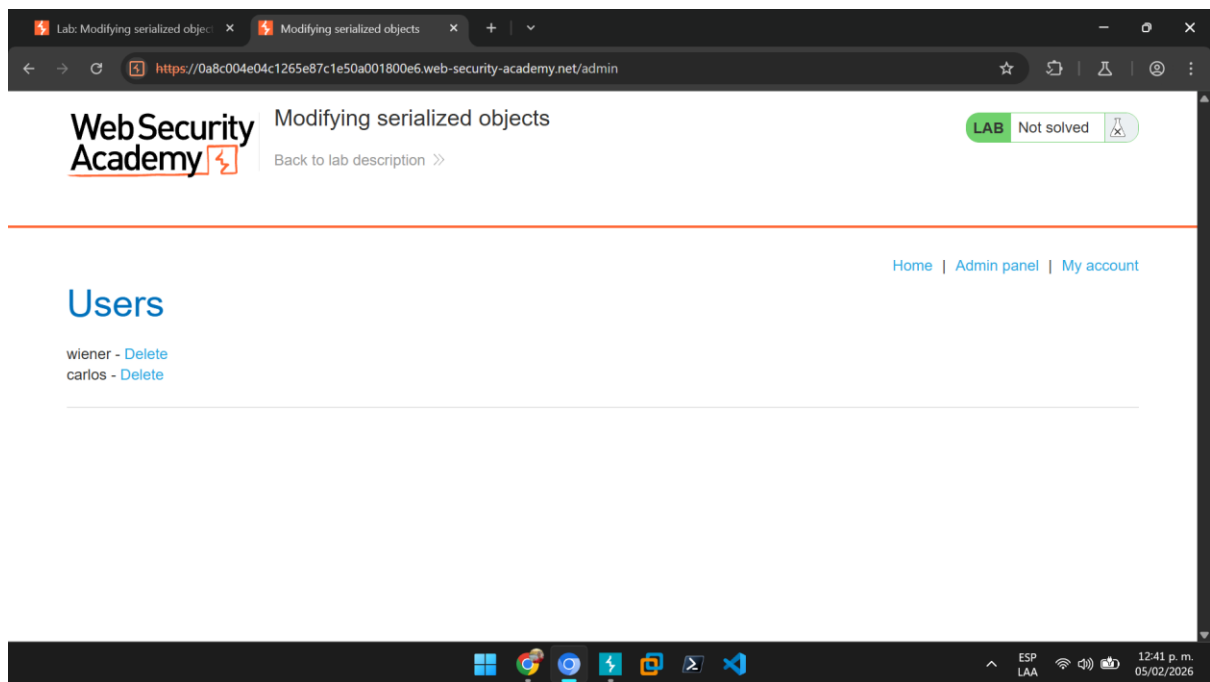


Como se puede ver aquí cambiamos la cookie de sesión para que el booleano de admin pase de 0 a 1. Le damos al botón Send de color naranja para enviar esta petición al sitio web. Y recibimos como respuesta un código 200 OK que nos confirma que hemos cambiado exitosamente la cookie para convertirnos en Administradores del sitio.



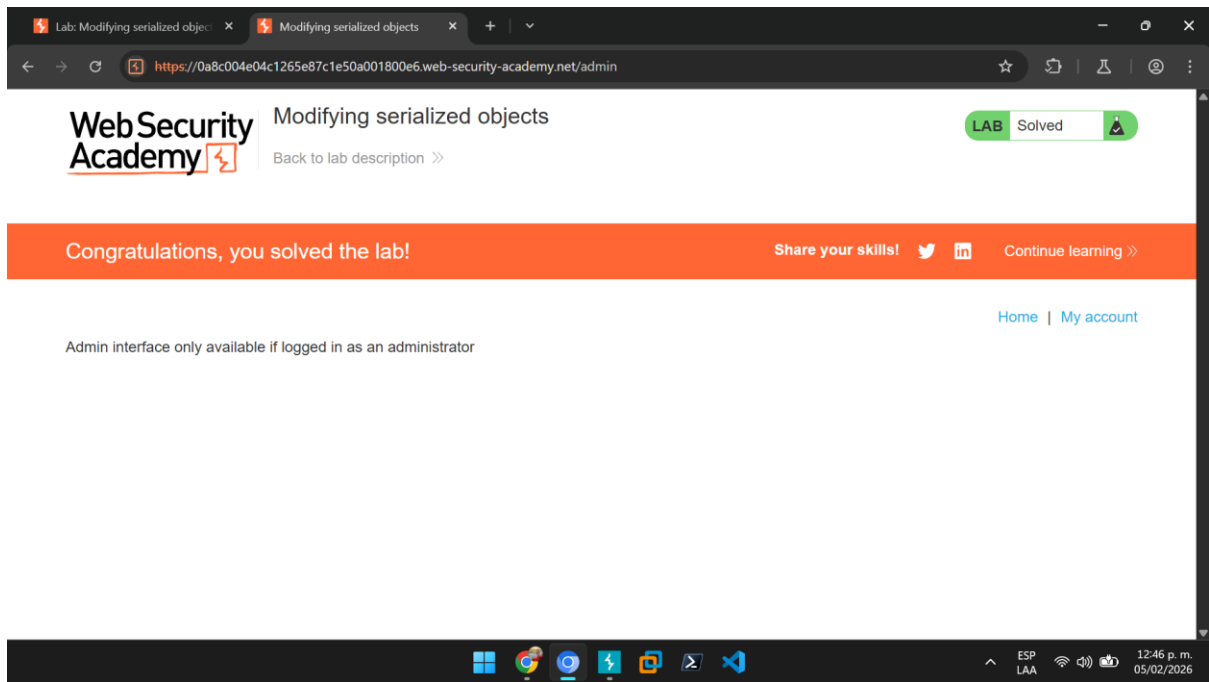


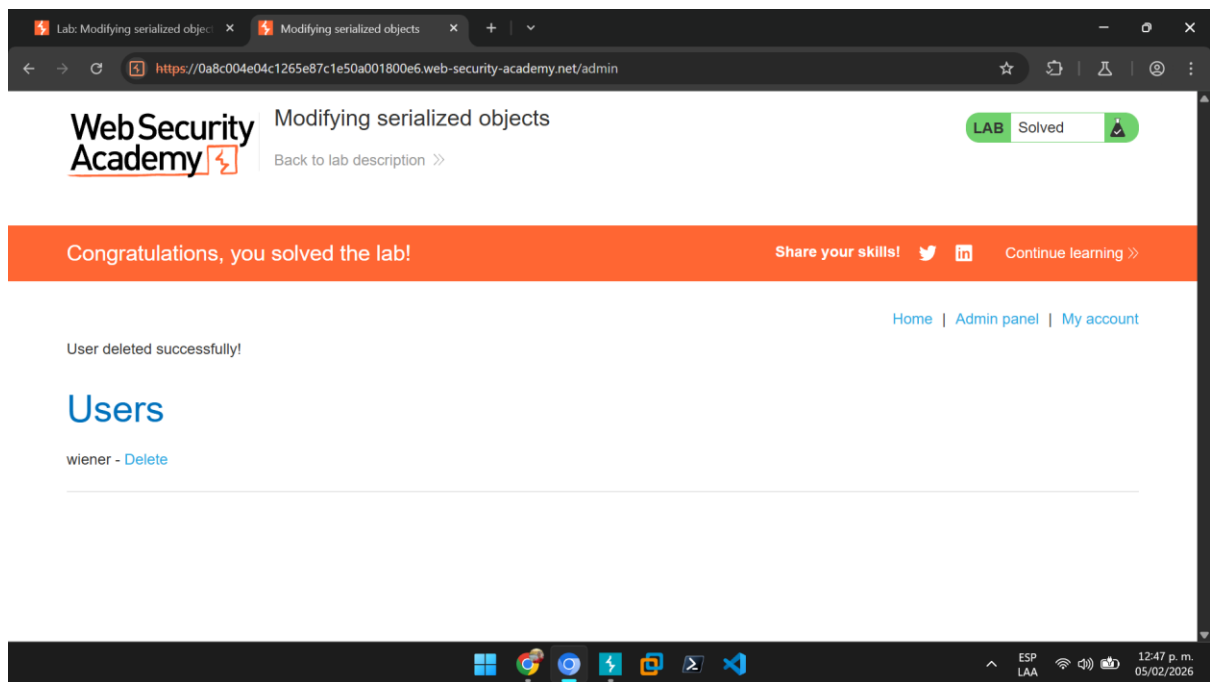
Para poder entrar en el sitio web y acceder ya oficialmente como admin necesitamos modificar ahora si en la interceptación con Burp Suite la cookie y establece el booleano en 1 como hicimos previamente.



¡Y Listo! Hemos ingresado como administradores del sitio vamos a eliminar al usuario Carlos como nos han indicado.

Por lo tanto, el usuario Carlos ya no existe.





Aquí podemos ver que el usuario Carlos ha sido eliminado correctamente y ya solo existe Wiener.

DESCRIPCIÓN DEL PROCESO Y CONCLUSIONES.

El proceso de explotación comenzó con el análisis del manejo de sesiones de la aplicación. Tras interceptar el tráfico mediante Burp Suite, se identificó que el sistema emplea objetos serializados en PHP dentro de la cookie de sesión para gestionar los atributos del usuario.

Utilizando la herramienta Inspector, se decodificó el objeto y se identificó un parámetro booleano de control de acceso denominado admin. Se procedió a realizar una manipulación de la integridad del objeto, cambiando su valor de 0 (False) a 1 (True). Al reenviar la petición modificada, el servidor deserializó el objeto confiando en la entrada del cliente, lo que permitió una escalada de privilegios vertical para acceder al panel administrativo y ejecutar la eliminación del usuario objetivo.

Conclusiones

Vulnerabilidad de Diseño: El laboratorio demuestra que la serialización no debe usarse como un mecanismo de seguridad por sí mismo, ya que es un formato de transporte de datos, no de protección.

Confianza Implícita: El error fundamental radica en confiar en datos provenientes del lado del cliente para definir permisos críticos. Cualquier dato que pase por el navegador del usuario debe ser tratado como hostil.

Mejores Prácticas: Como medida de mitigación, se recomienda el uso de firmas digitales (como HMAC) para asegurar la integridad de las cookies, o preferiblemente, mantener el estado de los privilegios exclusivamente en el lado del servidor.

REFERENCIAS BIBLIOGRÁFICAS.

- Portswigger. (2023). Access control security models.
- ¿Qué Es el Control de Acceso? - Sistemas de Ciberseguridad Red
| Fortinet, s. f.